

Case Study – SecOps Engineer 2026

Phần 1: Theoretical Exercise (Presentation)

Bối cảnh

Công ty đang xây dựng năng lực bảo mật hạ tầng. Hạ tầng gồm nhiều service (một số public-facing, một số internal-only), database layer, và một nền tảng Kubernetes on-premise đang vận hành. Truy cập vào hệ thống hiện còn phân tán (VPN truyền thống, một số truy cập trực tiếp), chưa có mô hình quản lý danh tính tập trung hay phân vùng mạng rõ ràng.

Yêu cầu

Ứng viên chuẩn bị một slide deck (5 slides, ~5 phút trình bày (nếu được vào vòng phỏng vấn)) với các nội dung sau:

- 1. Network Segmentation:** Đề xuất mô hình phân vùng (zone model) cho hạ tầng hybrid - có service public-facing, internal-only, và database layer. Nêu rõ Kubernetes cluster nên nằm ở đâu trong mô hình zone, và nguyên tắc phân vùng cùng lý do.
- 2. VPN truyền thống vs ZTNA / Identity-aware Proxy:** So sánh trade-off giữa 2 hướng cho remote access, đặc biệt trong bối cảnh một tổ chức có team vận hành mỏng. Khi nào nên chọn hướng nào.
- 3. IAM/SSO + PAM Foundation:** Đề xuất mô hình quản lý danh tính tập trung (SSO cho các internal apps) và Privileged Access Management cho truy cập đặc quyền (admin, SSH, database). Chỉ yêu cầu tư duy kiến trúc - không cần implement (phần thực thi nằm ở Phần 2).
- 4. KPI/Metrics:** Đề xuất 2–3 chỉ số để báo cáo BOD về mức độ trưởng thành của security infrastructure.

Sản phẩm nộp: PowerPoint/Google Slide/PDF (5 slides).

Phần 2: Practical Exercise (Hands-on)

Yêu cầu chung

Ứng viên nộp **01 repository GitHub public** (gửi link qua email) và **01 file PDF report** (3–5 trang) hướng dẫn cách chạy, giải thích thiết kế, và trình bày tư duy bảo mật. PDF là tài liệu chấm điểm chính.

Phạm vi thực hiện:

- **Task 1 và Task 2 là BẮT BUỘC.**
 - **Task 3 là TỰ CHỌN (bonus)**
-

Task 1 – Kubernetes Security Hardening (BẮT BUỘC)

Bối cảnh

Doanh nghiệp đang vận hành một Kubernetes cluster phục vụ các workload ứng dụng.

Trong phạm vi task này, có thể **giả định hạ tầng Kubernetes nền tảng đã được cấu hình an toàn**, bao gồm control plane, worker node, network infrastructure và các thành phần nền tảng khác.

Team SecOps nhận được yêu cầu đánh giá mức độ an toàn của một ứng dụng đang được deploy trên Kubernetes. Các manifest hiện tại được xây dựng chủ yếu để ứng dụng có thể chạy được, nhưng chưa trải qua security review đầy đủ.

Yêu cầu

Chuẩn bị một ứng dụng đơn giản và deploy lên Kubernetes bằng manifest mà ứng viên cho rằng có thể đại diện cho một workload thực tế trong doanh nghiệp.

Chủ động xây dựng hoặc lựa chọn một số **security weakness / misconfiguration ở tầng Kubernetes workload và manifest** để minh họa cho các rủi ro có thể xuất hiện trong thực tế.

Không giới hạn ở một danh sách lỗi hổng cụ thể. Ứng viên được khuyến khích lựa chọn các vấn đề mà mình cho là quan trọng và giải thích lý do.

Từ workload ban đầu, hãy thực hiện một security assessment và trình bày:

1. Identify

- Những security issue hoặc misconfiguration nào tồn tại?
- Chúng được phát hiện bằng cách nào?
- Có thể kết hợp static scanning, Kubernetes security tools, policy engine hoặc manual review.

2. Analyze

- Rủi ro của từng vấn đề là gì?
- Trong trường hợp workload hoặc container bị compromise, vấn đề đó có thể làm tăng mức độ ảnh hưởng như thế nào?
- Đánh giá mức độ ưu tiên xử lý của các finding.

3. Remediate

- Đề xuất và triển khai phiên bản manifest an toàn hơn.
- Giải thích các quyết định hardening đã thực hiện và trade-off nếu có.
- Sau khi remediation, chứng minh rằng workload vẫn hoạt động bình thường.

4. Detect & Prevent

- Nếu cùng loại misconfiguration xuất hiện trong các project khác, ứng viên sẽ phát hiện chúng như thế nào?
- Đề xuất cách đưa security check vào CI/CD thay vì phụ thuộc hoàn toàn vào manual review.
- Đề xuất các cơ chế có thể ngăn workload không tuân thủ security baseline được deploy vào cluster.

5. Operational Approach

- Giả sử đây là môi trường production đang tồn tại từ trước và có nhiều workload chưa được security hardening.
- Cần triển khai các security control mới như thế nào để hạn chế nguy cơ gây outage?

Output

- Source code hoặc sample application dùng cho demo.
- Kubernetes manifest trước và sau khi hardening.

- Các script hoặc hướng dẫn cần thiết để chạy demo.
- Báo cáo ngắn dạng PDF trình bày:
 - Các finding.
 - Risk và impact.
 - Cách phát hiện.
 - Remediation.
 - Cách phòng tránh tái diễn trong tương lai.
 - Đề xuất rollout security control trong môi trường production.

Task 2 – Secure Access Architecture: IAM hoặc ZTNA (BẮT BUỘC)

Ứng viên **chọn 1 trong 2 option** dưới đây. Đây là task đánh giá khả năng thiết kế và triển khai (ở mức POC) một lớp kiểm soát truy cập - ứng viên **tự chọn công cụ**, không bắt buộc stack cụ thể.

Option A – IAM / SSO

- **Design:** Thiết kế mô hình quản lý danh tính tập trung cho một hệ thống có 2-3 internal apps. Nêu rõ: identity provider chọn gì (Keycloak, Authentik, Zitadel, hoặc tương đương), mô hình group/role, cách map user → quyền trên từng app, và cách xử lý các trade-off (VD: quản lý role tập trung vs phân tán).
- **Partial implement (POC):** Dựng một POC nhỏ chứng minh luồng SSO/OIDC hoạt động - tối thiểu 1 app xác thực qua identity provider. Cho phép mock/giả lập nếu cần, nhưng phải giải thích rõ giả lập gì và giới hạn ở đâu.

Option B – ZTNA / Identity-aware Proxy

- **Design:** Thiết kế mô hình truy cập Zero Trust cho việc truy cập một web app internal và một target quản trị (SSH hoặc tương đương). Nêu rõ: proxy/gateway chọn gì (Pomerium, oauth2-proxy, hoặc tương đương), cách enforce policy theo identity/group, và **failure mode + break-glass** (điều gì xảy ra khi proxy down, admin truy cập khẩn cấp thế nào).
- **Partial implement (POC):** Dựng một POC nhỏ đặt proxy phía trước ít nhất 1 service, enforce một policy truy cập cơ bản theo identity. Cho phép mock/giả lập nếu cần, nhưng phải giải thích rõ.

Yêu cầu phân tích (trong PDF, áp dụng cho cả 2 option)

- Vì sao chọn công cụ đó (so với các lựa chọn khác)?
- Mô hình phân quyền/policy được thiết kế thế nào, và vì sao?
- Điểm yếu / rủi ro còn lại của thiết kế, và hướng khắc phục nếu triển khai thật ở quy mô lớn hơn.
- Hướng dẫn chạy demo POC.

Output

- Sơ đồ/mô tả thiết kế
- POC code/config (docker-compose hoặc tương đương)
- Mô tả trong PDF

Task 3 – Malware Reversing (TỰ CHỌN / BONUS)

Task này **không bắt buộc**. dành cho ứng viên muốn thể hiện thêm năng lực reverse engineering / phân tích. Không hoàn thành task này không ảnh hưởng đến việc đánh giá 2 task bắt buộc.

Bối cảnh

Ứng viên được cung cấp một **sample** (trong thư mục Drive chia sẻ). Đây là một mẫu dùng để kiểm tra khả năng reversing – không phải malware thực tế đang lây lan. Tuy nhiên, khuyến nghị phân tích trong môi trường tách biệt (VM/sandbox) như một thói quen bảo mật tốt.

File: https://drive.google.com/file/d/1BR_ipVWe1qtMQcoQlvZuEgl4Yansu8m9/view?usp=drive_link

Nhiệm vụ

- Phân tích hành vi của sample: nó thực hiện những hành động gì?
- Nếu có cơ chế mã hóa/encoding: xác định thuật toán và cách thức hoạt động.
- Nếu sample gửi/nhận dữ liệu: xác định dữ liệu gì được xử lý, gửi đi đâu (nếu có).
- (Nếu có) Đề xuất cách phát hiện hoặc khôi phục, tùy theo bản chất sample.

(Ứng viên mô tả ngắn gọn phương pháp cho từng bước, kèm hình ảnh/dẫn chứng nếu có. Có thể dùng static analysis, dynamic analysis, hoặc kết hợp – nêu rõ công cụ sử dụng.)

Output

- Mô tả quá trình và kết luận phân tích trong PDF (có thể là phần riêng trong PDF report chung, hoặc file PDF riêng).

Tổng kết hình thức nộp

Phần	Sản phẩm
Phần 1 – Presentation	Slide deck (5 slides): PowerPoint/PDF
Phần 2 – Task 1 (bắt buộc)	Repo GitHub: manifest before/after + script cluster + mô tả trong PDF
Phần 2 – Task 2 (bắt buộc)	Repo GitHub: design + POC (IAM hoặc ZTNA) + mô tả trong PDF
Phần 2 – Task 3 (bonus)	Phân tích reversing trong PDF

- Toàn bộ Phần 2 dùng **01 repository GitHub public duy nhất**.
- 01 file PDF report** (3–5 trang, chưa tính phần bonus) là tài liệu chấm điểm chính.